INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)

Governance, Compliance, and Risk (GCR)
Course 4: GRC104 – Compliance Frameworks and Legal Requirements

GRC104 Assignment: Comparative Incident & Security Breach Analysis

Student Name: Najma Abdi Omar

Reg. No: **2025/GRC/10331**

Date: 01/11/2025

Worldcoin Kenya and MGM Resorts: A Comparative Analysis of Cybersecurity Breaches

Executive Summary:

In this report, we analyze two cyber-related incidents from opposite ends of the global spectrum. The first incident examines the Kenyan context, focusing on a case that began investigations in 2023 for violating Kenya's Data Protection Act, 2019, and was concluded in May 2025 in favor of the Kenyan data subjects. The second incident explores the MGM Resorts Cyberattack which began as a social engineering attempt and escalated into a ransomware incident.

Each incident is analyzed independently, considering several Key factors including, the organization, the nature of the incident, applicable regulations, source of the report or the whistleblower, the response to the incident, its overall impact, and the lessons learned.

In the following sections, we present a side-by-side summary of both incidents based on the key factors mentioned in the detailed analysis of the individual incidents. We then provide a comparison of similarities and differences, followed by a brief conclusion highlighting the key lessons.

Several credible resources and reports were explored in the development of this report to ensure a comprehensive and well-informed analysis.

Detailed Analysis for Incident A: Worldcoin Kenya Data Privacy Breach Case Study

1. **Overview and Context**

We chose this incident to form context for a local view of incident handling, response and remediation. The world coin (Tools for Humanity GmbH) is a global cryptocurrency and digital identity project with headquarters in Germany and the United States, they were branching out and in Africa started operating in Kenya because of the booming tech scene and high existing boom in cryptocurrency adoption.

The incident highlights a data privacy breach and lack of adherence to local regulation, we chose this incident because it is an indicative of a lot of different aspects in approach to data privacy in Kenya, it explores the rise in adoption of data privacy in the African region and draws a picture of the systematic gap created and exploitation of humans due to lack of awareness, illiteracy, and poverty levels, at the same time highlighting how incidents are handled even from the regulator perspective and not just at organizational level.

2. **Regulatory and Security Environment**

The regulation that applies to this incident with Worldcoin operations in Kenya is the Kenya Data Protection Act, 2019 and Data Protection Regulation, 2021, enforced by the Office of the Data Protection Commissioner (ODPC).

Compliance violations contributed to this incident where violations were noted on the requirements of organizations operating in Kenya and dealing with Personal data to:

Conduct a Data Protection Impact Assessment (DPIA) before processing sensitive personal data, ensuring lawful and informed consent, and maintaining a data sovereignty i.e. storing and processing Kenyan Citizen data within approved jurisdiction.

This breach, considering the organization was operating with global presence, also violated global compliance regulations like GDPR.

3. Root Causes and Control Failure

The primary root cause was failure to conduct a mandatory DPIA prior to the collection of Biometrics of Kenyan citizens as per the requirements, even though the organization registered as a data controller in line with the regulations, Worldcoin lacked proper governance and compliance oversight in their process and failed to align with Kenya Data protection requirement. This failure to adhere to the requirements was the defining key of the incident which led to compliance violation.

There was also violation in the consent mechanisms, where many participants were not aware of the implications of sharing the Biometric data. There were cases of assumed or implied consent considering some participants were on boarded using the Worldcoin campaign staff's phone, illiteracy in some participants, these are an indication that consent was not properly informed or freely given especially considering there were incentives in form of tokens (crypto equivalent to $55 dollars which translates to roughly KES 7,000 in a nation where we have people living on less than a $1 or KES 129 a day).

The other factor speaking to compliance violation is the lack or insufficient disclosure around safeguards and data transfer and storage. The regulation has controls in place to safeguard the data of the citizens and specifies the procedures for transfer or storing data outside Kenya, which contributed to the incident.

4. **Detection and Disclosure**

This issue is an example of regulator stepping in when there are violations of compliance, in this incident, the issues was brought to the attention of the ODPC in mid-2023, when public and the media raised concerns about the Worldcoin' s data collection practices in Kenya. Following this reports the ODPC initiated investigations by its own volition to verify compliance with Kenya Data Protection Act.

5. **Response and Regulatory Actions**

The ODPC ordered Worldcoin to stop all biometric data collection and processing in August 2023 pending investigation, citing violation of Kenya's Data Protection Act, 2019, especially in the requirements for informed consent and conducting DPIA.

Worldcoin responded through the parent company Tools for Humanity, stating commitment to legal compliance, temporarily paused operations, committed to dialogue and engaged in legal challenges while attempting to relaunch the activities.

In mid-2024, after investigations were closed by the Directorate of Criminal Investigations (DCI), Worldcoin attempted to resume operations in Kenya, however ongoing legal cases initiated by civil society organizations in Kenya resulted in further court orders that halted the plans.

In May 2025, Kenyan High Court ruling renewed suspension and ordered Worldcoin to permanently erase all unlawfully collected Biometric data within 7 days, under the supervision of the ODPC, they claimed to have deleted the data and submitted an affidavit as proof of compliance with the specific ruling.

6. **Impact Assessment**

Although the government had requested the details of Kenyans who were registered, TFH sited they had no obligation to submit such a requesting indicating it will be a violation of individual data privacy. They however provided that the number of registered Kenyan Clients at the time of response was 508,569. This is a substantive number and helps us quantify the impact in some ways.

Other than the number of people and nature of data collected (Biometrics: Face, Iris and participant particulars), Worldcoin also suffered severe reputational damage in Kenyan Market and in the Global arena, undermining the public trust in the handling of the sensitive biometric data.

Even though there were no leaked data reported, privacy risks were significant due to the sensitive nature of the data they were collecting and considering the lack of transparency in obtaining, handling, transferring and storing.

Financially the company faced legal costs, and delays in operations and in the long run complete pause, waste of resources and time spent on the collection of the 508, 569 participant's data, not counting only the incentives but also the human capital, time and investments in the campaign.

Operationally they suffered suspension after the initial investigations opening and complete pause after the high court ruling of May 2025. It meant no work in Kenya leading to the disruption of expansion plans and considering Kenya was the first African nation chosen to operate.

In the Kenyan arena, this incident exposed the gap between policies and enforcement, even though the public trust in institutions was gained enhancing credibility of the ODPC as an active regulator.

7. Lesson Learned and Remediation

Lessons:

There were several lessons we take away from this incident and also spoke to the lesson for the regulator and the general public as well the organizations operating in Kenya.

For organization operating in Kenya: the need to ensure compliance with local regulations especially with regards to controls around collecting, transfer and storage of Kenyan data subjects, importance of conducting DPIAs and showing proof, securing informed consents without ambiguity, incentives or threats, and understanding of true meaning of informed consent, not implied, assumed or imposed.

For the regulator: Engagement with community, raising awareness, closing the Gap between policy and enforcement, and especially the highlighted incident in this incident where the ODPC was reactive after public outcry. The different approaches to dealing with awareness and especially in communities with emerging markets and with different levels of literacy and poverty level.

General Public: The need to seek education around the rights and approaches to sharing data, in this incident the nature of data collected and how willing Kenyans were queuing to submit data indicates there is a huge gap in Africa where people do not see the importance of data especially given incentives and where it is a choice between data and sleeping hungry.

Remediation:

Short Term: Where violations are noted, like in this incident, immediate cease unauthorized data collection and submit a retro DPIA to the ODPC.

Mid Term: Establishing strong governance and legal compliance frameworks, appointing a local data protection officer, improving public literacy on data use, and storage.

Long Term: A sustainable compliance culture, introducing privacy by design, and collaborating with regulators to ensure continued accountability and lawful cross-border data processing. Bridging the gap between policy, compliance, community and controls.

8. Accountability and Ethical Considerations

Although in this incident, there was no criminal liability other than the impact on the organization, what it highlights is the potential criminal liability under the Kenya Data Protection Act, 2019, and especially for individuals and entities processing personal data unlawfully or failing to comply with the directives, and how where deliberate violations are proven officers not just the organization would face penalties.

The whistleblower in this incident can be the general public and the media who raised concerns about the nature of operations prompting response from regulators. We see importance of having frameworks and policies that support and protect the whistleblower encouraging ethical reporting on privacy violations.

Detailed Analysis for Incident B: MGM Resorts International Ransomware Attack Case Study

1. Overview and Context

We chose this incident to get the perspective on the global approach to incidents and how mature industries handle incident reporting, response and compliance violations. And also, to highlight, that no matter how mature an industry is and the controls put in place the Human remain to be the strongest defense and the weakest link (and recently, after AI).

MGM Resort International is a large multinational hospitality, gaming and entertainment company operating numerous large resorts and casinos across the United States.

This incident was a result of social engineering which led to ransomware attacks. The MGM incident was triggered by using social engineering tactics where the attackers impersonated an employee and succeeded in manipulating the MGM's IT Helpdesk into disclosing and providing access credentials. This led to network compromise, system encryption and disruption of IT infra, impacting several systems including slot machines, hotel digital keys, reservations and websites, highlighting how social engineering is still a factor and key player in cybersecurity, it also shows transparency in reporting, and incident handling. And the importance of layered defense.

2. Regulatory and Security Environment

MGM nature of operations was on a global scale and had to adhere to several regulations and industry standards, including PCI-DSS, due to handling of payment card data collected form clients at the point of transacting or making reservations, California Consumer Privacy Act, and due to nature of business in the gaming industry also the Gaming Commission regulation and by extension due to involvement with EU citizens also the GDPR.

3. Root Causes and Control Failures

The cause of the incident was a combination of several factors which we highlight and briefly explain below:

Human: this was one of the primary root causes, social engineering and identity exploitation, the attackers gained access by manipulating the IT Helpdesk staff and convincing them via a call to reset credentials and grant access. The human element was exploited here which now gave room for the subsequent ransom attack.

Process: the ease with which the credentials were taken over speaks to the gap in process related to identity verification and security protocols. Inadequate helpdesk verification procedures allowed the attacker to exploit human trust utilizing social engineering, instead of vulnerabilities. This also points to gaps in processes in terms of user awareness training and resilience in the face of social engineering.

Technical: Credentials alone in this age of technology should not be sufficient for access, up to the level of lateral movement, the lack of MFA enabled the credential theft to escalate to environment compromise gaining access to the systems, Privilege access monitoring led to the unidentified movement to secure systems, lack of network segmentation led to access to critical zones using only credentials and the subsequent lateral movements leading to escalated permissions and opening room for a ransomware attack.

4. Detection and Disclosure

The incident handling and reporting was professional and spoke to mature industries level of response. Below we give a brief description of how the incident was handled.

The MGM resort put out a statement on X, formerly Twitter, that a Cyber Security Incident was impacting some of its systems. It is believed that the first breach on the network happened on September 8, the following day MGM security teams detected unusual activity and traffic on the Company's systems. It escalated quickly and operations were publicly disrupted.

Officially the effect of the incident began on 10th September 2023, when the resort started experiencing outages and unusual traffic. MGM promptly self-reported the attack and was proactive in shutting down the systems which are key contain breach. The attacker who later claimed the responsibility gave details in the underground world forums, MGM maintained transparency throughout. Detection in this case was internal and operationally driven, not by a regulator or third party.

5. Response and Regulatory Actions

The MGM team quickly responded by shutting down affected systems to protect their data and infra, and to allow breach containment even though this escalated the disruption. Third party agencies and leading cybersecurity experts were engaged to assist in containing and mitigating the attack, law enforcement were also contacted to investigate the breach.

Affected customers were informed and relevant authorities given incident disclosure reports as per regulatory compliance and transparency expectation. No major fines or executive penalties were reported, however there was reports of class-action suits over data negligence.

The MGM team also did not pay the ransom however, they opted to do system restoration, and enhanced cybersecurity measures were implemented.

6. Impact Assessment

There were significant operational, financial and reputational impacts, widespread service disruptions led to guests not accessing rooms, malfunctioning slot machines, halted reservations and onsite operations forced into manual mode. Financially the loss reported exceeds $100m due to downtime, remediation and lost revenue. The threat actors claimed to have accessed the PII of customers and employee although no confirmation of a data breach. The brand image also suffered due to the extensive coverage and comparison with another organization which had resumed operations faster because they paid the ransom. However, MGM opted not pay ransomware and sources say they were back in operations after 10 days.

7. Lesson Learned and Remediation

Lesson:

The attack exposed the underlying weakness in human factor defenses and access control process and realized the importance of strong identity verification, employee awareness training and multi-layered incident response planning. Also, the importance of layered defense and the need for network segmentation.

Remediation:

Short term: immediate password resets, enhanced MFA enforcement, isolating affecting systems, and public communication to restore trust.

Medium term: detailed security awareness campaign, improved incidence response and vendor review.

Long term: invest in ZTNA, PAM and an ongoing board level cybersecurity governance to ensure accountability. Shorten the gap between compliance and control enforcements because we can be compliant but not secure.

8. Accountability and Ethical Considerations

As of 2024 no arrests were reported from the sources explored, even though ALPHV/BlackCat ransomware group were identified as the threat actor, making the primary criminal exposure external.

No employee was held legally accountable although there was increased emphasis on the need for clear social engineering prevention. No whistle blower was involved in disclosure, operational disruption made the incident known.

Comparative Analysis of the Two Incidents:

In this section we give a line-by-line comparison of the nature of the incident, this section highlights the incidents based on the requirements listed in the Key Factor Column and forms a summary of the detailed analysis done in the previous section.

Key Factor (Incident)	Worldcoin Kenya Data Privacy Breach Case Study	MGM Resorts International Ransomware Attack Case Study
Affected Organization (Industry, size and Geographical Location)	Worldcoin (Tools for Humanity GmbH): Global cryptocurrency and digital identity project headquartered in Germany and the United States, operations in Kenya.	MGM Resorts International is a large multinational hospitality, gaming and entertainment company operating numerous large resorts and casinos across the United States.
The type of incident (data breach, ransomware, insider misuse, supply-chain compromise, etc.)	Data Privacy Breach: Unlawful biometric data collection and processing. The organization collected sensitive personal data, iris scans and facial images, violating Kenya's Data Protection Act, 2019.	Social Engineering & Ransomware attack, The MGM cyber incident was triggered using social engineering tactics where attackers impersonated an employee and succeeded in manipulating the MGM's IT Helpdesk into providing access credentials leading to compromise and subsequent Ransomware attack.
The security requirements and regulations relevant to that organization (examples: GDPR,	Operations in Kenya subjected Worldcoin to Data Protection Act, 2019 and Data Protection	Due to the global nature of operations and the location, and the nature of the business in the

HIPAA, PCI-DSS, SOX, local financial regulations, data localization laws)	General Regulations, 2021, enforced by the office of the data protection commissioner (ODPC).	hospitality and gaming industry, it subjected to PCI-DSS California Consumer Privacy Act , GDPR, Gaming Commission Regulation.
The root causes and control failures that enabled the incident (technical, process, and human factors)	The primary root cause was **failure to conduct mandatory Data Protection Impact assessment** prior to collecting biometric data of Kenyan Citizens as per the requirements. Compliance to the process and violation in consent mechanism and ambiguity or lack of disclosure in the transfer and storage of data.	The primary root cause was **social engineering** and Identity exploitation leading to ransomware and system disruptions.
The detection and disclosure timeline (who discovered the incident and how; self-reported vs discovered by regulator/third-party)	The issue was brought to the attention of the Office of the Data Protection Commissioner (ODPC) by the public and media.	The incident began on 10th September 2023, when the resort started experiencing outages and unusual traffic. MGM promptly self-reported the attack.
The organizational and regulatory response (notifications, remediation, fines, litigation, executive consequences)	The ODPC ordered Worldcoin to stop all biometric data collection and processing in August 2023 pending investigation. And the high court ruling of 2025 renewed and upheld the suspension.	System isolation, manual operations, collaborations with Cybersecurity experts and security, restoration of services.
Impact Assessment (data exposure, financial, reputational, operational, customer trust)	The data incident caused severe reputational damage to Worldcoin in Kenya and globally, In Kenya, even though this use case exposed regulatory enforcement challenges, it strengthened public awareness of data protection rights and enhanced the credibility of the ODPC as an active regulator.	There was significant operational, financial and reputational impacts, widespread service disruptions.
Lessons learned & prioritized roadmap remediation (short, medium, long-term controls; policy and governance changes)	Organizations collecting and storing sensitive data must ensure compliance with local data protection laws, conduct DPIAs and secure informed consents, importance of regulatory engagement in community awareness Short Term: Immediately cease unauthorized data collection and	Lesson: The attack exposed the underlying weakness in human factor defenses and access control process and realized the importance of strong identity verification, employee awareness training and multi-layered incident response planning. Short term: immediate password resets, enhanced MFA

	submit a retro DPIA to the ODPC. Medium Term: Establish strong governance and legal compliance frameworks, appoint a local data protection officer, improve public literacy on data use and storage. Long Term: A sustainable compliance culture, privacy by design and collaboration with regulators to ensure continued accountability and lawful cross-border data processing.	enforcement, isolating affecting systems, and public communication to restore trust. Medium term; detailed security awareness campaign, improved incidence response and vendor review. Long term: invest in ZTNA, PAM and an ongoing board level cybersecurity governance to ensure accountability.
Individual accountability and criminal exposure considerations, including the role of whistleblowers and protections where relevant	This case highlighted potential criminal liability under the Kenya Data Protection Act, 2019, and especially for individuals and entities processing personal data unlawfully or failing to comply with the directives, in this case we do not have individual prosecution reported, however where deliberate violations are proven officers could face penalties. No whistleblower disclosures were documented, the public's outcry and complaints acted as a collective reporting which prompted response from the regulator. This shows importance of having frameworks that encourage ethical reporting on privacy violations.	As of 2024 no arrests were reported from the sources explored, even though ALPHV/BlackCat ransomware group were identified as the threat actor, making the primary criminal exposure external. No employee was held legally accountable although there was increased emphasis on the need for clear social engineering prevention. No whistle blower was involved in disclosure, operational disruption made the incident known.

Comparison in Similarity and Differences:

Evaluating the two incidents, even though they differ in nature, there are several similarities in the root causes. Both highlight cybersecurity risks created by a gap in key areas:

1. **Lack of awareness and exploitation of the Human Element**

In both cases, human vulnerability was exploited which emphasizes how people remain a top factor in cybersecurity risk.

The Kenyan Worldcoin incident demonstrated how socio-economic factors can be manipulated to exploit individuals. Issues related to lack of awareness, illiteracy (extending to people who were on boarded by others on their behalf) and poverty created a situation where individuals had to choose between privacy and hunger. Many participants were unaware of the repercussions of selling their biometric data or signing up for something because it was free and in addition paid.

In contrast, the MGM cyber incident involved a different form of human exploitation, social engineering. The attacker manipulated an IT helpdesk officer into providing credentials, leading to a compromise of the organization's systems.

Despite the differences between the two incidents, one being potential breach and violation of regulations in Kenya, and the other a full-scale cyberattack, both incidents reveal a failure in human awareness and ethical responsibility.

2. **Gap Between Regulatory Compliance and Control Enforcement**

Both incident also expose a clear gap between having regulations in place and effectively enforcing them.

In the Worldcoin incident, the organization registered in Kenya as a data controller with the Office of the Data Protection Commissioner (ODPC, suggesting a degree of compliance. However, the violation which were ranging from improper consent collection to the absence of a Data Protection Impact Analysis (DPIA) and inadequate cooperation during investigation all illustrate a significant gap between compliance on paper and enforcement in practice.

Similarly, in the MGM incident, despite existing regulatory framework and cybersecurity standards, the breach which was triggered by a compromised credential that led to the disruption of the entire organization, reflects a gap between regulatory compliance and effective enforcements of security controls.

3. **Maturity gap in Incident Response and Reporting**

Another notable difference lies in how each incident was handled and reported, highlighting the gap between mature and emerging security cybersecurity frameworks and regulations.

In the Worldcoin case, there were delays in investigations, unclear timelines, and ambiguous data-handling practices. Even after the violations were identified, the organization sought to continue operations and only complied with the DPIA requirement after scrutiny began. The eventual closure of the case by DCI in 2024, which meant giving the Worldcoin go ahead to proceed operations, and subsequent high court ruling ordering data deletion and pause to operations, shows inconsistencies and lack of structured enforcement which could indicate a deeper regulatory weakness in Kenya.

At the same time, conducting research on this case revealed challenge in accessing consistent public information, evidence of limited transparency and weak reporting frameworks in Kenya and more broadly, Africa. This underlines the urgent need for structured reporting mechanisms and better public records to strengthen cybersecurity resilience through collaboration.

On the other hand, information about MGM incident was much easier to access, with detailed step-by-step reporting down to timelines on the occurrence, reporting and response. This demonstrated a mature reporting mechanism and a culture of accountability, further supported by MGM's swift collaboration with law enforcement and cybersecurity experts.

Conclusion

Both incidents offer important lessons from reporting and response to the realization that, regardless of an organization's maturity, cybersecurity is not a question of if but when. Strengthening awareness, bridging compliance and enforcement gaps, and improving transparency and collaboration are critical steps towards resilience in the evolving cybersecurity landscape.

References.

Office of the Data Protection Commissioner. (2024, February). *Complaint No. 1394 of 2023 determination*. https://www.odpc.go.ke/wp-content/uploads/2024/02/ODPC-COMPLAINT-NO.-1394-OF-2023-DETERMINATION.pdf

Makau, I. (2025, September 11). Kenya High Court's Worldcoin determination: Upholding consent, accountability and data sovereignty in biometric data processing. Centre for Intellectual Property and Information Technology Law. https://cipit.strathmore.edu/kenya-high-courts-worldcoin-determination-upholding-consent-accountability-and-data-sovereignty-in-biometric-data-processing/ cipit.strathmore.edu

Ardent Privacy. (n.d.). *Kenya High Court orders Worldcoin to halt biometric data collection and processing*. https://www.ardentprivacy.ai/blog/kenya-high-court-orders-worldcoin-to-halt-biometric-data-collection-and-processing/

Dig Watch. (n.d.). Worldcoin allowed to resume operations in Kenya after year-long probe. https://dig.watch/updates/worldcoin-allowed-to-resume-operations-in-kenya-after-year-long-probe

Schrader, D. (2025, February 14). *An overview of the MGM cyber attack*. Netwrix Blog. https://netwrix.com/en/resources/blog/mgm-cyber-attack/ Netwrix

Inszone Insurance. (n.d.). Cyber-attack at MGM Resort explained. https://inszoneinsurance.com/blog/cyberattack-mgm-resort-explained

B-Brown. (n.d.). A look back at the MGM and Caesars incident. https://www.bbrown.com/us/insight/a-look-back-at-the-mgm-and-caesars-incident/

West O A h u Global. (n.d.). Alphv hackers reveal details of MGM cyber attack. https://westoahu.hawaii.edu/cyber/global-weekly-exec-summary/alphv-hackers-reveal-details-of-mgm-cyber-attack/